Политика информационной безопасности "TechCorp"

1. Введение
Безопасность данных является приоритетом нашей компании. Все сотрудники обязаны соблюдать правила, описанные ниже, чтобы предотвратить утечки конфиденциальной информации.

2. Парольная политика
Пароли должны меняться каждые 90 дней. Запрещено использовать один и тот же пароль для разных сервисов. Длина пароля должна составлять не менее 12 символов, включая спецсимволы.

3. Удаленная работа
При работе из дома используйте только корпоративный VPN. Запрещено подключаться к рабочим ресурсам через публичные Wi-Fi сети (кафе, аэропорты) без использования VPN.

4. Классификация данных
Все информационные активы компании делятся на следующие категории:

* **Публичные:** Информация, доступная для внешних лиц (пресс-релизы, статьи в блоге).
* **Внутренние:** Данные для внутреннего использования сотрудниками (структура отделов, внутренние инструкции).
* **Конфиденциальные:** Данные, утечка которых может нанести ущерб компании (технические спецификации, дорожные карты продуктов).
* **Строго конфиденциальные:** Персональные данные клиентов, финансовые отчеты до их публикации, ключи доступа к серверам.

5. Управление доступом (IAM)
Доступ к информационным системам предоставляется по принципу "минимально необходимых привилегий" (Least Privilege).

5.1. Порядок предоставления доступа
Заявка на доступ создается в системе Jira. Одобрение должен дать непосредственный руководитель и владелец ресурса (Data Owner).

5.2. Ревизия прав
Раз в квартал отдел ИБ проводит аудит прав доступа. Если сотрудник сменил роль или отдел, его старые доступы должны быть аннулированы в течение 24 часов.

6. Использование рабочих станций и ПО
6.1. Установка стороннего софта
Сотрудникам запрещено устанавливать программное обеспечение из неавторизованных источников. Любое ПО, не входящее в "Стандартный пакет TechCorp", должно быть одобрено отделом IT-поддержки.

6.2. Режим Clean Desk

В конце рабочего дня на рабочих столах не должно оставаться бумажных документов, содержащих конфиденциальную информацию. Экран монитора должен блокироваться автоматически после 5 минут бездействия.

7. Инциденты информационной безопасности
В случае обнаружения подозрительной активности (фишинг, попытка несанкционированного входа, пропажа рабочего ноутбука) сотрудник обязан:
1. Немедленно отключить устройство от сети (если применимо).
2. Создать тикет с пометкой [URGENT] в системе мониторинга.
3. Сообщить по телефону горячей линии ИБ: +7 (999) 000-00-00.

8. Физическая безопасность
Доступ в серверные помещения разрешен только системным администраторам и сотрудникам эксплуатации. Запрещено передавать свои пропуска третьим лицам или проводить в офис посетителей без предварительной регистрации в системе гостевых визитов.

9. Ответственность
Нарушение положений данной Политики влечет за собой дисциплинарную ответственность, вплоть до увольнения и передачи дела в правоохранительные органы, если действия сотрудника привели к компрометации персональных данных клиентов.

10. Криптографическая защита
Все данные, передаваемые по внешним сетям, должны быть зашифрованы с использованием протоколов не ниже TLS 1.2.

11. Использование мобильных устройств (BYOD)
Личные смартфоны допускаются к рабочей почте только при установке MDM-профиля (Mobile Device Management), обеспечивающего удаленное стирание корпоративных данных.

12. Резервное копирование
Критически важные базы данных должны проходить процедуру бэкапа ежедневно. Раз в месяц проводится тестовое восстановление данных.

13. Уничтожение носителей
Вышедшие из строя жесткие диски и SSD подлежат физическому уничтожению (шредированию). Запрещен выброс накопителей в бытовой мусор.

14. Безопасность электронной почты
Запрещено открытие вложений от неизвестных адресатов. Все подозрительные письма должны пересылаться на адрес spam-report@techcorp.com.

15. Облачные сервисы
Использование сторонних облачных хранилищ (Dropbox, Google Drive) для хранения исходного кода и данных клиентов строго запрещено.

16. Безопасная разработка (SDLC)
Весь программный код должен проходить процедуру статического анализа (SAST) перед слиянием в основную ветку (main).

17. Управление уязвимостями
Критические уязвимости в инфраструктуре должны устраняться в течение 48 часов с момента обнаружения.

18. Проверка контрагентов
Перед предоставлением доступа к API партнеры должны пройти аудит безопасности и подписать соглашение о неразглашении (NDA).

19. Использование мессенджеров
Официальным мессенджером для обсуждения рабочих вопросов является корпоративный Slack. Запрещено обсуждение паролей в открытых каналах.

20. Обновление ОС
На всех рабочих станциях должна быть включена функция автоматического обновления безопасности операционной системы.

21. Двухфакторная аутентификация (2FA)
2FA является обязательной для всех сервисов: почта, VPN, GitHub, Jira, облачные панели управления.

22. Аудит системных логов
Логи доступа к серверам хранятся в течение 12 месяцев в неизменяемом виде (Write Once, Read Many).

23. Безопасность Wi-Fi в офисе
Гостевая сеть Wi-Fi должна быть физически изолирована от корпоративной сети.

24. Социальная инженерия
Ежеквартально проводятся учебные фишинговые атаки. Сотрудники, "попавшиеся" на фишинг, проходят повторный курс ИБ.

25. Работа в Open Space
Запрещено оставлять на мониторах стикеры с паролями или контактными данными клиентов.

26. Использование USB-носителей
Все USB-порты на рабочих станциях заблокированы. Доступ открывается по разовому запросу для переноса специфических данных.

27. Сканирование сети
Внутреннее сканирование сети на наличие открытых портов проводится еженедельно.

28. Защита рабочих станций (EDR)

На каждом компьютере должен быть установлен и активен агент системы обнаружения угроз (Endpoint Detection and Response).

29. Инвентаризация оборудования
Все аппаратное обеспечение должно иметь инвентарный номер и быть закреплено за конкретным материально ответственным лицом.

30. Удаление учетных записей
При увольнении сотрудника все его доступы блокируются в течение 1 часа после официального уведомления от HR.

31. Работа с открытым исходным кодом (OSS)
Запрещено использование библиотек с лицензиями, накладывающими ограничения на коммерческое использование ПО.

32. Тестирование на проникновение
Раз в год компания нанимает внешних аудиторов для проведения внешнего пентеста инфраструктуры.

33. Безопасность видеоконференций
Все встречи в Zoom/Teams должны быть защищены паролем и функцией "зала ожидания".

34. Приватность данных (GDPR)
Сбор персональных данных клиентов осуществляется только при наличии явного согласия (Opt-in).

35. Хранение логов приложений
В логи приложений запрещено записывать пароли, токены и полные номера банковских карт (PAN).

36. Сегментация сети
Производственная среда (Production) должна быть полностью изолирована от среды разработки (Staging/Dev).

37. Управление ключами шифрования
Ключи шифрования должны храниться в специализированных HSM-модулях или защищенных Vault-системах.

38. Работа в командировках
При поездках в страны с высоким уровнем киберугроз сотрудникам выдаются "чистые" временные ноутбуки.

39. Мониторинг даркнета
Служба ИБ обязана мониторить утечки учетных записей с доменом @techcorp.com на сторонних ресурсах.

40. Безопасность IoT

Все умные устройства в офисе (камеры, принтеры) должны находиться в отдельном VLAN без доступа к интернету.

41. Ответственное разглашение (Bug Bounty)
Компания поддерживает программу Bug Bounty для независимых исследователей безопасности.

42. Требования к веб-браузерам
Разрешено использование только последних версий Google Chrome и Firefox с установленным расширением корпоративного блокировщика рекламы.

43. Передача файлов
Для передачи файлов размером более 20 МБ внутри компании необходимо использовать внутренний файлообменник с авторизацией.

44. Доступ к исходному коду
Доступ к репозиториям предоставляется на основе ролей (Read/Write/Admin) и только для проектов, над которыми работает сотрудник.

45. Защита от DDoS
Все публичные сервисы должны быть защищены через WAF (Web Application Firewall).

46. Печать документов
Запрещено оставлять распечатанные документы в лотках общих принтеров.

47. Аудит кода (Code Review)
Ни одно изменение не может быть внесено в продакшн без одобрения как минимум одного другого разработчика.

48. Использование ИИ-инструментов
Запрещено копировать проприетарный код или данные клиентов в публичные чат-боты (ChatGPT и аналоги) без обезличивания.

49. План обеспечения непрерывности (BCP)
В случае отказа основного дата-центра, время восстановления сервисов не должно превышать 4 часов.

50. Пересмотр политики
Данная политика подлежит обязательному пересмотру и обновлению не реже одного раза в год или при значительных изменениях в ИТ-архитектуре.